技术贡献与可证实范围

工程候选代码：9f00b6ba7475e8bccc5410e1484ed74a7806b7d1

贡献一：把宿主登记的工具能力、预持有文件句柄、Guard 和效果审计连为执行前闭环。具体根因回归覆盖路径替换、首次凭据访问、命令权限、一次性审批和敏感 MCP 外传。

贡献二：把部署、接触、检测、隔离和阻断拆成独立事实，隔离蜜罐不接触真实资源。自适应选择只是启发式实现。

贡献三：公开结构化执行证据，意图 / 结果分离、请求摘要、政策版本及局部链验证。没有证明其为行业首创。

策略、AI 与权限延续

模型输出是建议。只有模糊风险进入事前 AI，suspicious 可收紧到 DENY，benign / 超时 / 无效 JSON 仍 REQUIRE_APPROVAL。

AI 没有 approve、reset 或修改策略的工具。宿主批准时复查 Guard、资源与敏感历史，批准引用不是可重放的令牌。

更换同一 Guard 的网关保留会话 HMAC 历史，防止宿主重配置意外清空已观测来源。

真实本地审查对恶意审批诱导返回校验后的 suspicious；小样本不能证明普遍抗审查注入，也没有独立因果阻断收益。

证据协议 v0.1

必需字段：schema_version、evidence_id、session_id、agent_id、tool_id、request_id、request_digest、policy_version、decision、decision_reason、approval_reference、execution_status、side_effect_verification、timestamp、previous_event_digest、event_digest。

对象键按 UTF-16 顺序，有限 JSON，UTF-8，无空白；排除 event_digest 后计算 SHA-256。不是完整 RFC 8785。请求摘要使用临时会话 HMAC，防止日志包含原始敏感参数。

可信 expectedHead 可检查链尾截断；无独立锚时，管理员可整体重写链。RUNNING 不代表执行完成，SUCCEEDED 也不自动代表全部外部效果已验证。

OpenTelemetry 属性映射可行，但 exporter 尚未实现，不能把 UUID 当作 OTel trace_id。

相关工作与演进

Promptfoo 的官方 red-team 文档介绍攻击样本生成、应用评测与 CI 集成，并有更广产品能力；这里比较其 red-team 工作流，不断言它只有评测。来源：https://www.promptfoo.dev/docs/red-team/

Microsoft PyRIT 是生成式 AI 风险识别研究框架。来源：https://github.com/Azure/PyRIT

Agent Canary 当前重点是宿主工具执行边界、隔离诱饵、Guard 与可核查的实际副作用。三者可以互补，本轮没有公平性能排名或功能优越性实验。

Apache-2.0 的专利许可与 NOTICE 管理值得评估；实际迁移需权利与兼容性审查，当前保持 MIT。Professional ¥99 买断仅为非核心管理便利模块规划，本轮无真实支付。